CVE-2026-115560 Threat Analysis & Technical Postmortem

PHP Session Upload Progress Remote Deserialization Vector (Target Scope: PHP 5.5 through PHP 8.4.xx)
Date: 2026-10-24 | Author: Andy Setiyawan | Environment: Akatsuki Lab (Fail-Closed)

1. Executive Summary

On 2026-10-23, public security advisories disclosed CVE-2026-115560, a vulnerability affecting PHP's RFC1867 session upload progress mechanism across PHP 5.5 through PHP 8.4.xx. Under deserialization-sensitive configurations, unauthenticated attackers can inject arbitrary session progress tracking arrays via multipart form payloads. Because upstream bugfix point releases are scheduled for the next regular maintenance cycle, this mitigation suite provides immediate perimeter filtering, runtime SAPI deactivation, and in-tree Zend Engine key sanitization across PHP 5.5 through PHP 8.4.xx.

2. Threat Model & Multi-CVE Coexistence

The attack surface comprises query string marker injection and RFC1867 multipart boundary poisoning with serializer delimiters (| ! ; {}). Sequential testing on a shared PHP 8.1 source tree confirmed that Patch 1 (CVE-109618-109619) and Patch 2 (CVE-115560) apply cleanly without clobbering (--fuzz=0). However, because Patch 1's early guard short-circuits at line 3000, runtime interaction is unverified unless Patch 1's guard is removed. SAPI drop-ins are isolated using 99-cve-2026-115560-hardening.ini.

3. Multi-Tier Defense Topology

Defense Tier	Component	Interception Mechanism	Effectiveness
Tier 1 (Perimeter Edge)	Nginx Reverse Proxy	cve-2026-115560-hardening.conf drops query string markers with HTTP 403	Immediate Perimeter Drop
Tier 2 (SAPI Runtime)	PHP-FPM / CLI SAPI	99-cve-2026-115560-hardening.ini disables session.upload_progress.enable	Runtime Deactivation
Tier 3 (Zend Core)	ext/session/session.c	Sanitizes progress key [a-zA-Z0-9_.-], len 1-128, blocks delimiters	Safely

4. Empirical Observations & Inconclusive Probes

Testing from akatsuki-lab (10.77.77.153) targeting php81-mitigation (10.77.77.199):

- **Perimeter Interception**: Query string markers dropped with HTTP 403 Forbidden.
- **Inconclusive Delimiter Probe**: Supplying an unescaped delimiter key (|) produced empty session data on both pristine and patched binaries under default PHP serialization, thus not demonstrating a binary delta.
- **Feature Preservation**: Supplying standard alphanumeric keys (valid_upload_123) successfully registered progress tracking on both binaries.
- **Scope Demarcation**: Runtime configuration hardening verified across nine sampled environments (PHP 5.5 - 8.4).